Phase 7: Threat Modeling — STRIDE Analysis

Course Code: 20CYS401 | **Project**: Online Book Review and Recommendation Platform

7.1 Asset Inventory (10 Assets)

Asset ID	Asset Name	Description	Sensitivity
ASSET-01	User Credentials	Passwords and authentication artifacts	Critical (Confidentiality)
ASSET-02	Session Tokens	Signed session cookies identifying authenticated users	High (Confidentiality & Integrity)
ASSET-03	User Profile Data	User account details (email, username, registration timestamp)	Medium (Confidentiality)
ASSET-04	User Reviews & Ratings	User opinions, scores (1-5), and text feedback on books	High (Integrity)
ASSET-05	Book Catalog Data	Book records (title, author, ISBN, descriptions)	Medium (Integrity)
ASSET-06	Personal Reading Lists	Books tracked by specific users and reading statuses	Medium (Confidentiality)
ASSET-07	Administrator Privileges	Admin flag granting catalog modification and moderation rights	Critical (Integrity)
ASSET-08	Audit Log Records	Immutable chronological trail of system and security events	High (Integrity & Non-repudiation)
ASSET-09	Secret Keys & Configuration	`SECRET_KEY`, database paths, environment configurations	Critical (Confidentiality)
ASSET-10	Health & System Metrics	Container health status, error details, and logs	Medium (Availability)

7.2 STRIDE Threat Matrix (10 Mapped Threats)

Threat ID	Threat Category	Target Asset	Description	Mitigation Control	Residual Risk
THR-01	**S**poofing	ASSET-01	Attacker impersonates legitimate user via brute force or credential guessing	CTRL-01: Bcrypt password hashing (rounds=12), rate-limited authentication, strict input validation	Low
THR-02	**T**ampering	ASSET-04	Attacker modifies another user's review by changing `review_id` in POST request (IDOR)	CTRL-02: Strict server-side ownership checks (`review.user_id == current_user.id`) in service layer	Very Low
THR-03	**R**epudiation	ASSET-07, ASSET-08	Admin deletes catalog items or hides reviews and denies taking the action	CTRL-08: Tamper-evident `AuditLog` recording actor, IP, timestamp, action, and rationale	Very Low
THR-04	**I**nformation Disclosure	ASSET-02, ASSET-09	Session token intercepted over network or exposed to client-side scripts	CTRL-01, CTRL-09: Cookies set with `HttpOnly` , `SameSite=Lax` , strict CSP headers	Low
THR-05	**D**enial of Service	ASSET-10	Attacker floods search endpoint with unindexed complex queries	CTRL-04, CTRL-07: Query length limits, parameterized ORM querying, resource constraints	Low
THR-06	**E**levation of Privilege	ASSET-07	Regular user accesses `/admin/*` routes to alter books or delete accounts	CTRL-06: Strict `@admin_required` decorator enforcing server-side role validation	Very Low
THR-07	**T**ampering	ASSET-04	Attacker injects malicious JavaScript into review content to execute XSS in other users' browsers	CTRL-03: Contextual Jinja2 autoescaping, text sanitization stripping null bytes and HTML	Very Low
THR-08	**T**ampering	ASSET-05	Attacker submits SQL syntax into search bar to leak database or modify tables	CTRL-05: Parameterized ORM queries (`SQLAlchemy`), zero string-concatenated SQL queries	Very Low

Threat ID	Threat Category	Target Asset	Description	Mitigation Control	Residual Risk
THR-09	**S**poofing	ASSET-02	Cross-Site Request Forgery: Third-party website submits unauthorized review edits	CTRL-01: Synchronizer Token Pattern (CSRF tokens required on all POST/PUT/DELETE forms)	Very Low
THR-10	**I**nformation Disclosure	ASSET-08, ASSET-09	Sensitive credentials or stack traces leaked via error responses or logs	CTRL-07, CTRL-08: Generic error pages (400, 403, 404, 500) without tracebacks; sensitive fields scrubbed from audit logs	Low